

Varakumar G

varakumar7000@gmail.com | +916309856263 | linkedin.com/in/varakumar01
GitHub | GitLab | Portfolio | Letter of Recommendation

PROFESSIONAL SUMMARY

Security Engineer with 2+ years in **Vulnerability Assessment and Penetration Testing (VAPT)** across web apps, APIs, networks, **Active Directory**, and **OT/ICS**. Independently assessed and exploited a live billing platform end-to-end — **IDOR, privilege escalation, SQL injection, XSS** — and reported it through a **GitHub Security Advisory**. Executes AD attack paths (**Kerberoasting, pass-the-hash**) and validated **2,800+ CVEs** in OT Security within a year, solo, scoring and prioritizing each with **CVSS** against **OWASP Top 10** and **MITRE ATT&CK**.

Automated plugin development for OT security to keep pace with the volume, and I contribute to **open-source** security testing projects because I want the tools I depend on to stay secure.

TECHNICAL SKILLS

Security Domains: Penetration Testing, Vulnerability Assessment, Active Directory, AppSec & API Security, ICS/OT Security

Exploitation & Security Testing: Metasploit, Burp Suite, Nmap, Wireshark, Postman, crAPI, VAmPI, Hashcat

Network & Security Protocols: IPsec, Kerberos, LDAP, TLS/SSL, DNS, DHCP, SNMP, SMB, RDP, SSH, HTTP/HTTPS

OT/ICS & Industrial Protocols: Modbus, BACnet, EtherNet/IP, DNP3, PROFINET

Vulnerability & Cloud Scanning: Nessus, OpenVAS, Qualys, CloudSploit, NVD, CVSS, AWS, Microsoft Azure, GCP, Oracle Cloud

Frameworks & Standards: OWASP Top 10, MITRE ATT&CK, NIST CSF, CIS Benchmarks, CVSS, PCI-DSS, ISO 27001

Programming & Platforms: C, Python, Node.js, Bash, MongoDB, MySQL, Kali Linux, Arch Linux, WireGuard

PROFESSIONAL EXPERIENCE

Holm Security AB | Security Engineer

Randstad.in

- Reproduced and validated **OT/SCADA vulnerabilities** against real vendor advisories, growing **CVE coverage from 400 to 3,200+** within a year — a **700% increase** in the company's SCADA/OT coverage — scoring each with **CVSS** and ruling out false positives so effort tracked real exploitability.
- Assessed OT security products from **Siemens, Schneider Electric, Rockwell Automation, ABB, Emerson, and Honeywell**, proving exploit conditions against each vendor's protocol stack.
- Assessed the **CloudSploit platform end-to-end** across **AWS, Azure, GCP, and Oracle** against **CIS Benchmark** controls, contributing reviewed fixes upstream.
- Automated security-check development using **Claude AI**, then walked clients through findings with remediation guidance and re-validated fixes.

Independent Security Assessment

- **Bill Manager (E-commerce/Billing App) — Independent Web Application Assessment:**
 - Assessed and exploited a live billing application end-to-end: **broken access control** between user and admin roles, **insecure direct object reference (IDOR)** on invoices/billing records, **privilege escalation** via role/parameter tampering, **SQL injection** on login and search fields, **stored/reflected XSS**, an insecure password-reset flow, and weak **session/JWT** handling.
 - Reported every finding with remediation guidance through a **GitHub Security Advisory** on the project repository.
- **Active Directory Security Assessment:**
 - Executed core AD attack paths end-to-end: **Kerberoasting, LLMNR/NBT-NS poisoning, pass-the-hash**, and **privilege escalation** via misconfigured **ACLs**.
 - Building toward advanced AD attack-path expertise: **ADCS abuse (ESC1 to ESC8)**, **delegation attacks** (unconstrained, constrained, resource-based), **Shadow Credentials**, and **BloodHound**-driven attack path analysis.
- **Web & API Security Testing (PortSwigger Web Security Academy):**
 - Exploited **SQL injection, XSS, CSRF, authentication bypass, access control, SSRF, XXE**, and **insecure deserialization** labs hands-on, carrying the same techniques into **API security testing** on **crAPI/VAmPI**.

PROJECTS

- **Subdomain & Attack Surface Enumeration Tool** | Python, Requests, dnspython
Turns a target scope into a prioritized attack surface: enumerates subdomains from public sources like **crt.sh**, **brute-forces** the remainder over **DNS**, then scans open ports and fingerprints each host's stack with **OpenVAS** plus custom backend-fingerprinting plugins.
- **Self-Maintained OpenVAS Scanner** | Nmap, NASL
Maintain a fork of **OpenVAS** carrying custom **NASL** plugins for **CVE** checks the default feed doesn't cover, plus fingerprinting logic for newer software. AI-automated scripts keep the feed current as CVEs are published, so findings map to exploitable conditions, not stale signatures.
- **Local Lab Setup**
 - **Active Directory lab:** Built a **domain controller** and client machines to run full attack chains hands-on — **Kerberoasting, LLMNR poisoning, privilege escalation**.
 - **pfSense + Vulnerable VMs:** Home lab behind a **pfSense** firewall with intentionally vulnerable targets (**Metasploitable, DVWA, VulnHub**) covering the full recon-to-exploit flow.

CERTIFICATIONS

- Offensive Security Certified Professional (OSCP) | OffSec | *In Progress*
- TCM Security: Practical Ethical Hacking • Windows & Linux Privilege Escalation • OSINT Fundamentals • External Pentest Playbook

EDUCATION

Malla Reddy College of Engineering & Technology, Hyderabad, India
Bachelor of Technology (B.Tech), Computer Science

2018 – 2022